AWS CLOUD DEFESA EM PROFUNDIDADE ZERO TRUST

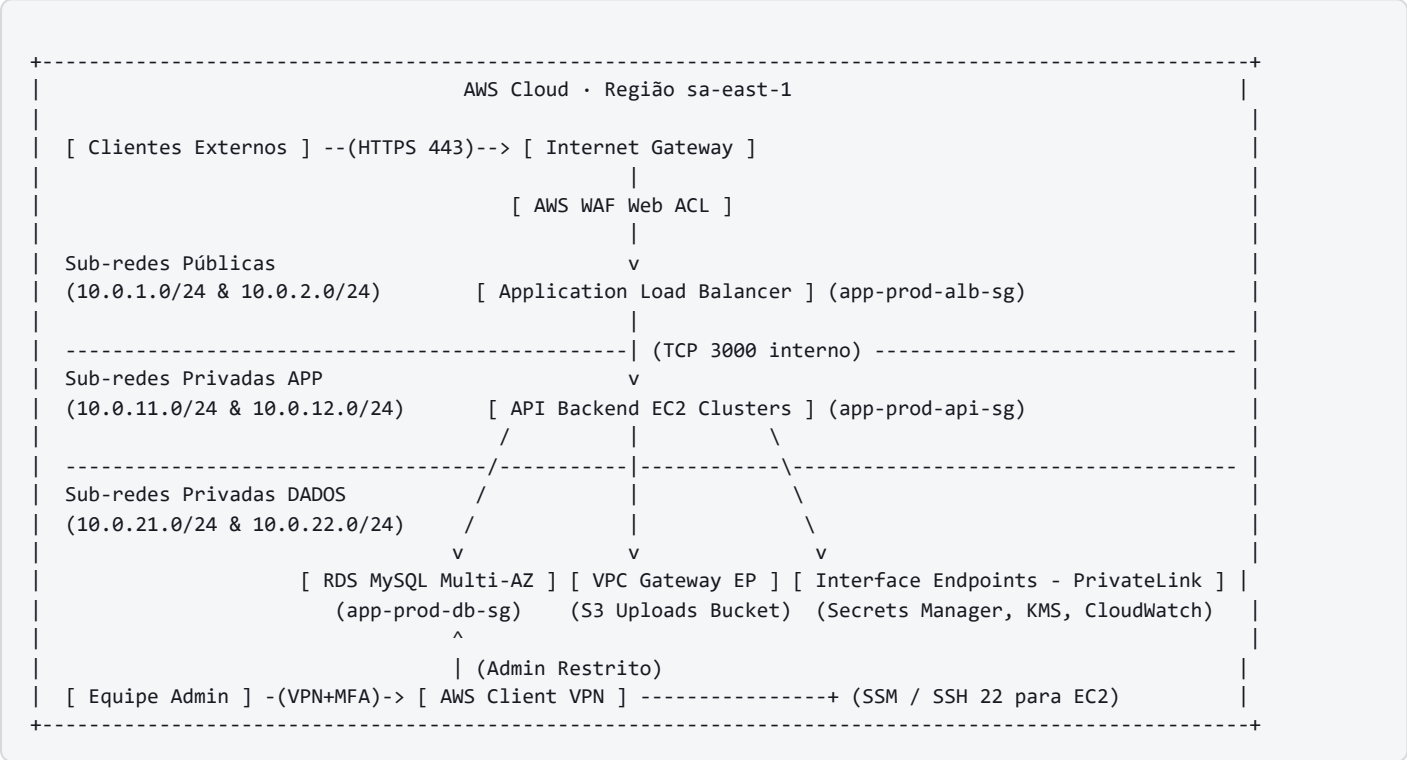
Documentação dos Fluxos de Comunicação

Projeto: Arquitetura Cloud Segura **Região:** sa-east-1 (São Paulo) **VPC:** 10.0.0.0/16 **Artefato:** fluxos.pdf

1. VISÃO GERAL E TOPOLOGIA DE REDE

A arquitetura foi projetada para atender integralmente aos requisitos de isolamento, resiliência e confidencialidade. Nenhum componente interno possui endereço IP público ou rota direta de entrada pela Internet. Toda a infraestrutura está contida em uma **Virtual Private Cloud (VPC)** com CIDR `10.0.0.0/16`, dividida em três camadas estruturadas e distribuída em duas Zonas de Disponibilidade (**sa-east-1a** e **sa-east-1b**):

- **Sub-redes Públicas (10.0.1.0/24 e 10.0.2.0/24):** Hospedam exclusivamente o *Application Load Balancer (ALB)* protegido pelo *AWS WAF* e conectado ao *Internet Gateway (IGW)*.
- **Sub-redes Privadas de Aplicação (10.0.11.0/24 e 10.0.12.0/24):** Hospedam as instâncias EC2 da API Backend e o endpoint do *AWS Client VPN*. Sem IP público e sem rota para a Internet.
- **Sub-redes Privadas de Dados (10.0.21.0/24 e 10.0.22.0/24):** Hospedam o cluster *Amazon RDS MySQL Multi-AZ* (Primário na AZ-a e Standby na AZ-b). Isolamento completo.
- **Conectividade Privada com Serviços AWS:** Todos os acessos ao *Amazon S3*, *AWS Secrets Manager*, *AWS KMS* e *CloudWatch* trafegam por **VPC Endpoints** (Gateway e PrivateLink), dispensando NAT Gateways para a internet.



2. MATRIZ DE CONEXÕES PERMITIDAS (WHITELISTING ESTRITO)

Cada fluxo foi planejado de acordo com a política de menor privilégio. A tabela a seguir especifica todas as comunicações autorizadas:

ID	ORIGEM	DESTINO	PROTOCOLO / PORTA	MECANISMO DE CONTROLE	FINALIDADE E JUSTIFICATIVA DE SEGURANÇA
FL-01	Internet pública `0.0.0.0/0`	Application Load Balancer (ALB)	`TCP 443 (HTTPS)`	`app-prod-alb-sg` + AWS WAF Web ACL	**Ponto de entrada público único.** Conexões TLS com certificado ACM. O AWS WAF bloqueia SQLi, XSS, rate-limit e bots antes do ALB.
FL-02	Internet pública `0.0.0.0/0`	Application Load Balancer (ALB)	`TCP 80 (HTTP)`	`app-prod-alb-sg` + Listener ALB	**Redirecionamento automático.** Porta 80 atende unicamente para emitir redirecionamento HTTP 301 para HTTPS (443). Dados em trânsito sempre criptografados.
FL-03	ALB Público `app-prod-alb-sg`	Instâncias API EC2 `app-prod-api-sg`	`TCP 3000`	`app-prod-api-sg` (Referência por ID de SG)	**Encaminhamento de requisições web.** O ALB distribui carga para as instâncias privadas. O SG da API rejeita pacotes de qualquer outra origem que não seja o ALB.
FL-04	Instâncias API EC2 `app-prod-api-sg`	Amazon RDS MySQL `app-prod-db-sg`	`TCP 3306`	`app-prod-db-sg` (Referência por ID de SG)	**Transações de banco de dados.** As instâncias EC2 da API consultam e persistem registros no RDS Primário. Tráfego contido estritamente na VPC privada.
FL-05	RDS Primário (AZ-a) `app-prod-db-sg`	RDS Standby (AZ-b) `app-prod-db-sg`	`TCP 3306`	Segurança interna gerenciada AWS RDS	**Replicação síncrona Multi-AZ.** Garante alta disponibilidade, redundância contra falha de data center e RPO zero entre AZ-a e AZ-b.
FL-06	Instâncias API EC2 `app-prod-api-sg`	Gateway Endpoint S3 `pl-xxxxxxx (AWS S3)`	`TCP 443 (HTTPS)`	Tabela de rotas privadas + Bucket Policy S3	**Armazenamento de arquivos de usuários.** Upload e leitura em bucket S3 privado sem tráfego por internet. Acesso condicionado ao ID do Endpoint e IAM Role.
FL-07	Instâncias API EC2 `app-prod-api-sg`	Interface Endpoints `app-prod-vpce-sg`	`TCP 443 (HTTPS)`	`app-prod-vpce-sg` + AWS PrivateLink	**Segredos e Criptografia.** Recuperação das credenciais do RDS no *Secrets Manager* e operações de cifragem/decriptação no *AWS KMS* via link privado.
FL-08	Instâncias EC2 / ALB / RDS / VPC	CloudWatch Logs e Métricas	`TCP 443 (HTTPS)`	Interface VPC Endpoint (vpce-logs)	**Observabilidade e auditoria.** Coleta de métricas operacionais, logs da aplicação Node/Python, logs de acesso do ALB e VPC Flow Logs para auditoria contínua.
FL-09	Estações Admin autorizadas	AWS Client VPN Endpoint	`UDP/TCP 443`	`app-prod-vpn-sg` + MFA / Certificados	**Canal administrativo seguro.** Estabelece túnel VPN criptografado. Exige autenticação multifator (MFA) e validação de credenciais de administradores.

ID	ORIGEM	DESTINO	PROTOCOLO / PORTA	MECANISMO DE CONTROLE	FINALIDADE E JUSTIFICATIVA DE SEGURANÇA
FL-10	Client VPN `app-prod-vpn-sg`	Instâncias API EC2 `app-prod-api-sg`	`HTTPS 443 / TCP 22`	`app-prod-api-sg` + IAM SSM Policies	**Gerenciamento de servidores.** Prioritário via *AWS Systems Manager Session Manager* (sem portas abertas). Porta 22 (SSH) aceita conexões somente do CIDR da VPN.
FL-11	Client VPN `app-prod-vpn-sg`	Amazon RDS MySQL `app-prod-db-sg`	`TCP 3306`	`app-prod-db-sg` (Regra explícita restrita)	**Manutenção extraordinária de banco.** Acesso administrativo direto pontual para DBAs/DevOps, com autorização de rede e auditoria de sessão.
FL-12	Todas as Interfaces (ENIs da VPC)	CloudWatch Logs / S3	`HTTPS 443`	VPC Flow Logs Service Role	**Registro de tráfego de rede.** Captura metadados de pacotes aceitos e rejeitados para detecção de anomalias, auditoria de segurança e perícia forense.

3. MATRIZ DE CONEXÕES BLOQUEADAS (POSTURA DEFAULT-DENY)

Seguindo a política de menor privilégio e isolamento de camadas, toda comunicação não explicitamente permitida é barrada. A tabela abaixo detalha os principais bloqueios de arquitetura e sua relevância de segurança:

VETOR DE COMUNICAÇÃO	ORIGEM	DESTINO	PORTA / PROTOCOLO	MECANISMO	RISCO MITIGADO
BLOQUEADO **Acesso direto à API**	Internet pública `0.0.0.0/0`	Instâncias EC2 da API Backend	Qualquer porta (3000, 80, 443)	Sub-rede Privada (sem IGW) + SG restrito	Ataques de negação de serviço direto, bypass do firewall de aplicação (WAF) e varreduras de vulnerabilidade.
BLOQUEADO **Acesso público ao Banco**	Internet pública `0.0.0.0/0`	Amazon RDS MySQL	TCP 3306	Sub-rede de Dados isolada + flag `Publicly Accessible=False`	Vazamento massivo de dados, tentativas de brute-force e ataques de ransomware contra a base relacional.
BLOQUEADO **Tráfego direto do ALB ao Banco**	ALB Público `app-prod-alb-sg`	Amazon RDS MySQL	Qualquer porta	`app-prod-db-sg` (sem regra de entrada)	Vetores de Server-Side Request Forgery (SSRF) e contaminação cruzada caso o balanceador fosse comprometido.
BLOQUEADO **SSH aberto para o mundo**	Internet pública `0.0.0.0/0`	Instâncias EC2 API / Bastion	TCP 22 (SSH)	`app-prod-api-sg` (rejeição explícita de 0.0.0.0/0)	Ataques automatizados de força bruta SSH, comprometimento de chaves privadas e exploits de zero-day no OpenSSH.
BLOQUEADO **Acesso HTTP em texto plano**	Clientes Web	ALB / Backend API	TCP 80 (cargas úteis)	Listener ALB HTTP:80 com regra de Redirect 301	Interceptação de credenciais, espionagem de tráfego de rede e ataques de Man-in-the-Middle (MitM).
BLOQUEADO **Acesso público a arquivos no S3**	Internet pública `0.0.0.0/0`	Bucket S3 de Uploads	HTTP / HTTPS	S3 Block Public Access (100% On) + Bucket Policy	Exposição acidental de arquivos de clientes, violação da LGPD/GDPR e indexação não autorizada por mecanismos de busca.
BLOQUEADO **Saída irrestrita para Internet**	Instâncias EC2 da API	Internet pública	Qualquer protocolo / porta	Ausência de NAT Gateway na VPC privada	Exfiltração de dados por malwares, comunicação com servidores de Comando e Controle (C2) e download de exploits.
BLOQUEADO **Tráfego lateral entre servidores**	Instância EC2 API A	Instância EC2 API B	Portas não declaradas	`app-prod-api-sg`	Movimentação lateral de ameaças dentro do cluster em caso de comprometimento pontual de uma instância.
BLOQUEADO **Exploits Web conhecidos (L7)**	Atacantes da Internet	ALB / Aplicação	HTTP/HTTPS maliciosos	AWS WAF Managed Rulesets	Ataques catalogados na OWASP Top 10 (SQL Injection, Cross-Site Scripting, RCE e Path Traversal).

4. ESPECIFICAÇÃO DETALHADA DOS SECURITY GROUPS

1. app-prod-alb-sg (Camada de Borda / Entrada Pública)
• **Ingress:** TCP 443 de `0.0.0.0/0` (HTTPS público seguro); TCP 80 de `0.0.0.0/0` (apenas redirecionamento 301 para 443).
• **Egress:** TCP 3000 com destino restrito ao identificador do grupo `app-prod-api-sg`.

2. app-prod-api-sg (Camada de Aplicação / Processamento)
• **Ingress:** TCP 3000 originado unicamente de `app-prod-alb-sg`; TCP 22 restrito ao CIDR administrativo de `app-prod-vpn-sg`.
• **Egress:** TCP 3306 destinado a `app-prod-db-sg`; TCP 443 destinado a `app-prod-vpce-sg`; TCP 443 destinado à Prefix List do S3.

3. app-prod-db-sg (Camada de Dados / Persistência)
• **Ingress:** TCP 3306 originado unicamente de `app-prod-api-sg`; TCP 3306 condicional de `app-prod-vpn-sg` para tarefas de administração.
• **Egress:** Sem regras amplas de saída. Apenas tráfego de resposta às consultas (natureza stateful) e replicação interna Multi-AZ.

4. app-prod-vpce-sg (Camada de Serviços Gerenciados AWS PrivateLink)
• **Ingress:** TCP 443 originado estritamente de `app-prod-api-sg` (Secrets Manager, KMS, CloudWatch Logs e SSM).
• **Egress:** Resposta às chamadas de API internas das interfaces elásticas privadas (ENIs).

5. app-prod-vpn-sg (Camada de Acesso Administrativo e Manutenção)
• **Ingress:** UDP/TCP 443 a partir de endereços administrativos na internet mediante autenticação forte e MFA.
• **Egress:** TCP 443 (SSM) e TCP 22 para `app-prod-api-sg`; TCP 3306 para `app-prod-db-sg` sob regra de autorização explícita do Client VPN.

5. DETALHAMENTO DOS FLUXOS OPERACIONAIS FIM A FIM

Fluxo A: Requisição Web Segura do Usuário e Processamento

1. **Iniciação da Sessão:** O usuário envia uma requisição HTTPS para o domínio corporativo. O DNS resolve o alias para os IPs elásticos do ALB nas sub-redes públicas A e B.
2. **Filtragem no WAF:** O *AWS WAF* intercepta a requisição e valida a assinatura contra regras gerenciadas da AWS (reputação de IP, mitigação de SQLi, XSS e flood rate-limiting). Se maliciosa, a conexão é descartada com código 403 Forbidden.
3. **Término TLS e Distribuição:** O ALB desembala a conexão TLS com o certificado emitido pelo *AWS Certificate Manager (ACM)* e escolhe um nó íntegro de API com base no algoritmo de balanceamento.
4. **Comunicação Interna Segura:** A requisição é encaminhada na porta TCP `3000` para a instância EC2 na AZ privada correspondente. O `app-prod-api-sg` autoriza o pacote por reconhecer o ID do SG do balanceador.

Fluxo B: Conexão Segura ao Banco de Dados Relacional

1. **Autenticação sem Senhas no Código:** A API invoca o *AWS Secrets Manager* através do **Interface VPC Endpoint** (TCP 443) utilizando credenciais temporárias obtidas via sua **IAM Role** de instância.
2. **Abertura de Conexão:** A API obtém a string e credenciais e estabelece conexão TCP na porta `3306` com o endpoint do RDS MySQL.
3. **Isolamento Físico e Lógico:** O pacote trafega estritamente dentro da VPC até a sub-rede privada de dados. O `app-prod-db-sg` permite a entrada do tráfego unicamente porque a origem é o `app-prod-api-sg`.
4. **Replicação Automática:** Concomitantemente, qualquer transação de escrita é sincronizada de modo síncrono com a instância Standby na AZ-b, mantendo réplica idêntica sem expor portas adicionais.

Fluxo C: Upload e Armazenamento Privado de Arquivos (Amazon S3)

1. **Recepção do Objeto:** O usuário envia um arquivo através da API.
2. **Roteamento via Gateway Endpoint:** A instância EC2 faz um `PutObject` na API S3 (`https://s3.sa-east-1.amazonaws.com`). A tabela de rotas da sub-rede privada intercepta o CIDR do S3 e desvia o tráfego para o **Gateway VPC Endpoint** (`vpce-s3`), mantendo o pacote dentro da infraestrutura interna da AWS sem tráfego de internet.
3. **Validação de Políticas de Segurança:** O S3 valida que o *S3 Block Public Access* está 100% habilitado e a *Bucket Policy* exige que a chamada se origine do identificador específico do VPC Endpoint da empresa.
4. **Criptografia em Repouso:** O objeto é gravado com cifragem no lado do servidor utilizando chave gerenciada pelo cliente no KMS (**SSE-KMS**), garantindo controle total sobre quem pode decriptar os dados.

Fluxo D: Manutenção Administrativa Segura e Auditoria

1. **Túnel Criptografado com MFA:** O operador administrativo conecta-se ao **AWS Client VPN** na porta 443, passando por verificação multifator obrigatória.
2. **Acesso sem Portas Abertas (AWS SSM):** O administrador gerencia os servidores EC2 prioritariamente através do **AWS Systems Manager Session Manager**, que encapsula comandos via canal TLS protegido por IAM, dispensando chaves SSH e eliminando a necessidade de Bastion Hosts.
3. **Trilhas e Rastreabilidade Total:** Todas as ações administrativas são registradas no **AWS CloudTrail** (quem realizou, quando, de qual IP e qual parâmetro foi enviado). As sessões de terminal podem ser gravadas em buckets S3 com retenção imutável.
4. **Monitoramento de Rede:** O **VPC Flow Logs** captura dados de todas as conexões permitidas e rejeitadas, enviando os eventos para o **Amazon CloudWatch Logs** com alertas configurados para picos de conexões negadas.

6. CONFORMIDADE COM OS REQUISITOS DO PROJETO

A solução atende rigorosamente a cada uma das diretrizes formuladas na proposta acadêmica:

- **Requisito 1 (HTTPS obrigatório):** Tráfego externo TLS/HTTPS 443 obrigatório no ALB, com redirecionamento de HTTP 80 para HTTPS.
- **Requisito 2 (Proteção e distribuição de tráfego):** AWS WAF associado ao ALB para proteção L7 e distribuição de carga com alta disponibilidade.
- **Requisito 3 (Processamento seguro na API):** Instâncias EC2 em sub-redes privadas sem IP público, comunicando-se internamente com recursos restritos.
- **Requisito 4 (Banco de dados inacessível publicamente):** RDS MySQL em sub-redes privadas dedicadas, sem rota pública e com acesso exclusivo pela API (3306).
- **Requisito 5 (Armazenamento controlado de arquivos):** Bucket S3 com Block Public Access ativo, acessado privadamente via Gateway Endpoint e protegido com SSE-KMS.
- **Requisito 6 (Acesso administrativo seguro):** AWS Client VPN com autenticação MFA e gerenciamento sem chave SSH via AWS Systems Manager.
- **Requisitos 7 e 9 (Menor Privilégio e Comunicações Mínimas):** Security Groups encadeados por ID de grupo, ausência de regras abertas para a Internet e IAM Roles temporárias.
- **Requisito 8 (Auditoria e monitoramento contínuo):** CloudWatch Logs e Métricas, CloudTrail para trilhas de governança e VPC Flow Logs em todas as ENIs.
